

Stonehaven Advisory Partners, LLC

Privacy and Cybersecurity Practices

Document owner	Chief Compliance Officer
Approved by	Managing Partner
Effective date	August 18, 2025
Version	1.0
Classification	Internal Policy - Fictional Test Document

This fictional document is part of the RegSpan realistic testing corpus. It is written as an ordinary company policy, not as a model answer or legal opinion.

Document Control

Version	Effective date	Summary of change	Approval
1.0	August 18, 2025	Current approved issue	Managing Partner

Policy Overview

Stonehaven is a boutique investment adviser with 14 employees, a cloud CRM, shared drives, custodian portals, and outsourced technology support.

The sections below describe the firm's approved practices. Department procedures may provide additional implementation detail.

1. Purpose, Scope, and Applicability

Stonehaven is a boutique investment adviser with 14 employees, a cloud CRM, shared drives, custodian portals, and outsourced technology support.

This document establishes the firm's internal approach to protecting customer information and responding to information-security events. It applies to employees, temporary personnel, contractors, offices, information systems, paper records, and relevant service-provider relationships.

Business units may maintain more detailed procedures, but those procedures may not reduce the protections stated here. Legal and Compliance interpret regulatory obligations and resolve conflicts with other retention, privacy, cybersecurity, or contractual requirements.

2. Definitions

Term	Working definition
Customer information	A record containing nonpublic personal information about a customer of a financial institution, including information handled by or on behalf of the firm and information provided by another financial institution about its customers.
Sensitive customer information	Customer information whose compromise could create a reasonably likely risk of substantial harm or inconvenience to an identified individual.
Customer information system	Information resources and related infrastructure used to collect, process, maintain, use, share, disseminate, or dispose of customer information.
Service provider	A person or entity that receives, maintains, processes, or is permitted access to customer information through services provided directly to the firm.
Incident	Unauthorized access to or use of customer information, or an event reasonably likely to involve such access or use.

3. Roles and Responsibilities

Role	Core responsibilities
Executive sponsor	Provides authority, resources, and escalation support.
Incident Response Lead	Directs triage, response activities, documentation, and closure.
Information Security / Technology	Investigates, contains, restores, and validates systems.
Compliance and Legal	Interprets notice, recordkeeping, regulatory, and law-enforcement obligations.
Business and data owners	Identify affected processes, systems, information, and customers.
Service-provider owner	Coordinates vendor evidence, notices, remediation, and follow-up.
Communications / Customer Service	Prepares approved customer communications and handles inquiries.

4. Written Security Incident Program

Stonehaven Advisory Partners, LLC maintains this written incident response program as part of its customer information safeguards framework. The program is reasonably designed to detect, respond to, and recover from unauthorized access to or use of customer information. It applies to customer information in paper, electronic, and other forms, including information maintained by service providers on the firm's behalf.

The program begins when monitoring, employee reporting, a service-provider notice, or another reliable source indicates that unauthorized access or use has occurred or is reasonably likely to have occurred. The Incident Response Lead opens a case, assigns severity, preserves relevant records, and coordinates assessment, containment, customer-notice analysis, recovery, and closure.

- Detect: monitor security alerts, access anomalies, customer complaints, lost devices, vendor notices, and misuse reports.
- Respond: investigate, contain, control, communicate, and document decisions.
- Recover: restore approved services, remediate root causes, validate controls and access, and complete a post-incident review.

5. Initial Investigation and Control Measures

The response coordinator performs an initial review of the event, identifies the systems believed to be involved, and consults business owners about operational impact. The team may isolate systems, reset credentials, or increase monitoring.

The review records the operational impact, the systems believed to be involved, and the immediate technical steps selected by the response coordinator.

6. Customer Notification Decision and Timing

Compliance determines whether customer notice is required under applicable law after the incident investigation is substantially complete. The firm seeks to notify affected customers within 30 days after confirming that sensitive information was compromised.

The notice schedule is measured from the date the investigation confirms compromise of sensitive information.

7. Customer Notice Preparation

Public statements and customer communications are coordinated by Legal and Corporate Communications. No employee may contact customers about an incident without approval.

Corporate Communications selects the format and delivery channel after considering the audience and available contact information.

8. Vendor Due Diligence and Incident Notice

Business owners monitor important service providers and escalate security concerns to Compliance. Written agreements may include breach-notification terms.

Oversight activities are documented in the vendor file and reviewed during contract renewal.

9. Administrative, Technical, and Physical Safeguards

The safeguards program applies to customer information in the firm's possession and customer information handled or maintained on its behalf. It also applies to nonpublic personal information received from another financial institution about that institution's customers. Controls are selected to ensure confidentiality, protect against anticipated threats or hazards, and prevent unauthorized access or use that could result in substantial harm or inconvenience.

- Administrative safeguards: risk assessment, assigned ownership, workforce training, access approval, change management, service-provider oversight, and periodic control review.
- Technical safeguards: multi-factor authentication, least privilege, encryption in transit and at rest where appropriate, endpoint protection, vulnerability management, secure configuration, logging, monitoring, and tested backups.
- Physical safeguards: controlled office and records-room access, visitor management, locked storage, secure transport, clean-desk expectations, and destruction controls for paper and media.

10. Disposal of Customer and Consumer Information

Electronic devices are wiped before disposal and paper files are shredded when no longer needed.

Department managers approve device disposal after confirming that local business files have been removed.

11. Program Documentation

Incident and vendor records must be retained for a minimum of three years unless Legal directs otherwise.

The records are stored in the compliance repository and may be retained longer when the matter remains open.

12. Incident File and Evidence Preservation

Technology closes support tickets after the reported problem is resolved. Employees should keep relevant emails until the issue is complete.

Support tickets are archived according to the help-desk system's ordinary retention settings.

13. External Authority Coordination

Only senior management may contact regulators or law-enforcement authorities. Employees should refer external inquiries to Legal.

Legal manages any follow-up with the requesting authority and informs management of next steps.

14. Corrective Action and Post-Incident Review

After containment, the firm returns systems to service and monitors for recurring issues.

Technology monitors the restored environment for recurring problems during the next business cycle.

15. Annual Privacy Notice Administration

Compliance reviews annually whether the firm must deliver privacy notices and coordinates any required mailing or electronic delivery.

Approval

Policy owner	Chief Compliance Officer	Date	August 18, 2025
Approving body	Managing Partner	Version	1.0